Plan de respuesta a incidentes — MTG Companion

Versión: 2.0 (7 nov 2026) · reemplaza el plan de la Actividad N°5 (§4 de `ACTIVIDAD_5.md`), que sigue vigente en lo que aquí no se cambia
Responsable del documento: Grupo MTG Companion (Vicente Fuentes, Tomás Rodriguez, Tomás Solano)
Ámbito: los datos personales del inventario del Hito 1 y la infraestructura que los contiene:

- cuentas, transacciones, ubicación cifrada, secretos 2FA, fotos de cartas, solicitudes de derechos y registro de auditoría;
- backend y PostgreSQL en EC2, bucket S3, AWS Secrets Manager (`JWT_SECRET`, `FIELD_ENCRYPTION_KEY`, `PSEUDONYM_KEY`) y el repositorio de código.

Marco legal: Ley 19.628 en el texto de la Ley 21.719, vigente desde el 01-12-2026: art. 14 quinquies (deber de seguridad) y art. 14 sexies (reporte de vulneraciones). Texto verificado en la BCN.

Novedades de esta versión (Actividad N°7):

- cuatro alertas propias del sistema;
- registro de accesos a datos personales;
- reconstrucción de incidentes desde el registro (`incident:timeline`);
- criterios de severidad por alerta;
- guía de actuación por tipo de incidente;
- plantillas completas de notificación.

---

1. Qué es un incidente

Un **incidente de seguridad de datos personales** es cualquier hecho que comprometa la confidencialidad, integridad o disponibilidad de los datos del ámbito. En la redacción del art. 14 sexies, es lo que ocasione "la destrucción, filtración, pérdida o alteración accidental o ilícita de los datos personales … o la comunicación o acceso no autorizados a dichos datos".

1.1 Cómo se detecta

Origen	Ejemplos
Regla automática sobre el registro de auditoría (`detection-rules.ts`)	Las 11 reglas de §2
Verificación de la cadena	`audit.chain.broken`
Reporte de un titular	Respuesta al aviso "tu correo cambió", correo al buzón de seguridad, formulario de derechos
Reporte de un tercero o hallazgo propio	*Security advisory* en GitHub, secreto encontrado en el repositorio o en un log, aviso de AWS

Un reporte manual se registra como alerta y sigue el mismo flujo.

1.2 Niveles

Son los estados de `security_alerts`. Cada cambio exige una nota y queda auditado.

Nivel	Estado	Qué significa	Quién decide
Alerta	`OPEN`	Una regla o un reporte la generó	Automático
Evento sospechoso	`INVESTIGATING`	Un humano la revisó y hay indicios reales	ADMIN de turno
Incidente confirmado	`CONFIRMED`	Hay evidencia de compromiso de datos personales: **se activa este plan completo**	Líder del incidente
Falso positivo	`DISMISSED`	Se descarta con justificación	ADMIN de turno
Cerrado	`CLOSED`	Se cumplieron las condiciones de §5.6	Líder del incidente

---

2. Criterios de severidad

2.1 Por alerta (severidad inicial)

La severidad de una alerta es la **inicial**. El análisis (§5.2) la confirma o la cambia según el impacto real.

Regla	Qué la dispara	Severidad inicial	Contención automática	Datos en riesgo
`auth.bruteforce`	≥ 5 contraseñas incorrectas contra una cuenta en 15 min	ALTA	Bloqueo de la cuenta 15 min	credenciales
`auth.credential-stuffing`	≥ 20 logins con correos inexistentes en 5 min	ALTA	—	credenciales
`auth.step-up.failures`	≥ 3 reautenticaciones fallidas desde una sesión válida en 15 min	ALTA	Revocar sesiones	todos los de la cuenta
`data.export.burst`	≥ 3 exportaciones completas en 24 h	MEDIA	—	todos los de la cuenta
`support.read.burst`	≥ 20 consultas del soporte a cuentas ajenas en 1 h	MEDIA	—	transacciones
`access.denied.burst`	≥ 5 intentos denegados a rutas de administración en 10 min	MEDIA	—	—
`audit.chain.broken`	La verificación de la cadena falla	ALTA	—	registro de auditoría
`bazaar.location.triangulation`	≥ 5 búsquedas con distancia desde celdas de ~1 km **distintas** en 10 min	**ALTA**	**Revocar sesiones**	**geolocalización** de los vendedores

Regla	Qué la dispara	Severidad inicial	Contención automática	Datos en riesgo
`account.takeover.sequence`	Cambio del correo seguido de exportación completa o supresión en < 1 h	**ALTA**	**Revocar sesiones**	todos los de la cuenta
`transactions.enumeration`	≥ 5 lecturas denegadas de transacciones, comprobantes o perfiles ajenos o inexistentes en 10 min	MEDIA	—	transacciones de terceros
`admin.reidentification.burst`	≥ 5 re-identificaciones de seudónimos por un ADMIN en 1 h	**ALTA**	— (la decide un humano: afecta al personal)	identidad detrás de los seudónimos

2.2 Por impacto (severidad confirmada)

Severidad	Criterio	Escalamiento	Tiempo de respuesta
Baja	Solo intentos (DENIED o FAILED) y ningún acceso a datos	Responsable de turno	Análisis ≤ 72 h; cierre ≤ 7 días
Media	Acceso indebido a datos de **pocas cuentas** (≤ 10), sin credenciales, llaves, transacciones ni ubicación	Líder del incidente	Análisis ≤ 24 h
Alta	Acceso o filtración de **credenciales o llaves**, de **transacciones**, de **ubicación**, de **más de 10 cuentas**; registro manipulado; abuso de un rol de personal	Todo el equipo, **de inmediato**	Contención ≤ 1 h desde la confirmación; evaluación de notificación ≤ 24 h

La clasificación sale de la **reconstrucción** (§5.2):

- `summary.affectedSubjects` da cuántas cuentas;
- `summary.dataCategories` da qué categorías;
- `outcome` dice si hubo acceso real (ALLOWED) o solo intentos.

---

3. Responsables

3.1 Roles

Es una propuesta del grupo y se confirma al aprobar el plan.

Rol	Titular	Suplente	Responsabilidades
Líder del incidente (responsable de seguridad)	Vicente Fuentes	Tomás Rodriguez	Clasifica, decide el escalamiento y la notificación, coordina y cierra
Desarrollo	Tomás Rodriguez	Vicente Fuentes	Causa raíz en el código, corrección, prueba que reproduce el ataque, lectura de la reconstrucción
Administración del sistema	Tomás Solano	Tomás Rodriguez	Preserva la evidencia, contiene (scripts, AWS, rotación de secretos), restaura

Rol	Titular	Suplente	Responsabilidades
Comunicación	Vicente Fuentes	Tomás Solano	Redacta las notificaciones, registra las comunicaciones y es el contacto con la Agencia y los titulares

Reglas:

- **Ninguna notificación externa sale con una sola firma:** la aprueban el líder y un segundo integrante.
- **Si el incidente involucra a un integrante** (por ejemplo, `admin.reidentification.burst` sobre su cuenta), ese integrante no participa en el análisis ni en la decisión, y su suplente asume.

3.2 Matriz RACI

R = ejecuta · A = responde · C = consultado · I = informado

Actividad	Líder	Desarrollo	Administración	Comunicación
Triage de la alerta	A	C	R	I
Preservar evidencia (`incident:snapshot`)	A	I	R	I
Reconstrucción (`incident:timeline`)	A	R	C	I
Clasificar la severidad	R/A	C	C	I
Contención	A	C	R	I
Erradicación (corrección y rotación)	A	R	R	I
Recuperación	A	C	R	I
Decidir si se notifica	R/A	C	C	C
Redactar y enviar la notificación	A	I	I	R
Lecciones aprendidas	R/A	R	R	R

---

4. Herramientas

Herramienta	Para qué	Quién
`GET /admin/security/alerts`, `PATCH /admin/security/alerts/:id`	Ver y clasificar alertas	ADMIN
`GET /admin/security/incidents/:alertId/timeline` (`?format=md`)	**Reconstruir el incidente desde el registro:** verifica la cadena, ordena los eventos por fase, lista las cuentas afectadas y las categorías de datos	ADMIN
`npm run incident:timeline -- --alert <id> --out ficha.md`	Lo mismo **sin la API**, por si la API está caída o comprometida	Administración
`npm run incident:snapshot -- --out <dir>`	Copia firmada (SHA-256) del registro y las alertas	Administración
`GET /admin/security/audit/verify`	Integridad del registro	ADMIN
`POST /admin/security/users/:id/revoke-sessions` · `/disable` · `/enable`	Contener o recuperar una cuenta	ADMIN

Herramienta	Para qué	Quién
`npm run incident:revoke-all-sessions -- --confirm`	Cerrar todas las sesiones	Administración
`PATCH /admin/users/:id/role`	Quitar un rol de personal (lo hace otro ADMIN)	ADMIN
`POST /admin/pseudonyms/resolve` (con motivo)	Identificar a quién notificar. Queda auditado, y 5 en 1 h levantan una alerta	Líder del incidente
Secrets Manager + `deploy-backend.sh`	Rotar llaves	Administración

---

5. Fases

5.1 Preparación (continua)

Rutinas:

- revisar las alertas `OPEN` cada semana;
- verificar la cadena después de cada despliegue;
- ensayar el plan una vez por semestre con una simulación. La de la Actividad N°7 es la primera: `evidencia/actividad7/`.

Mantener al día: este plan, el catálogo de eventos auditados (`audit-events.ts`) y los contactos del §3.

Requisito para cualquier operación nueva sobre datos personales: debe quedar registrada. La prueba `audit-events.spec.ts` falla si una acción nueva no está en el catálogo.

5.2 Detección y análisis

Paso	Qué se hace	Plazo
1	Llega la alerta: queda en `security_alerts` y se avisa al buzón de seguridad	Automático
2	**Preservar:** `incident:snapshot` y anotar en la ficha el hash del manifiesto	Antes de tocar nada
3	**Reconstruir:** `incident:timeline` o el endpoint. Primero se mira `Cadena de integridad`: si está **ROTA**, el incidente pasa a ALTA y la reconstrucción solo vale hasta `brokenAt`	≤ 1 h
4	**Responder con la reconstrucción:** ¿quién? (sujeto), ¿cuándo? (primer y último evento), ¿qué hizo? (eventos por fase), ¿llegó a datos? (`ALLOWED` en ACCESO A DATOS o EXFILTRACIÓN), ¿de quién? (`affectedSubjects`), ¿qué categorías? (`dataCategories`)	≤ 24 h
5	Clasificar según §2.2 y pasar la alerta a `INVESTIGATING`, `CONFIRMED` o `DISMISSED` con una nota	Con el paso 4

5.3 Contención

Las acciones van de menor a mayor impacto. Todas son reversibles y auditadas, y **ninguna borra datos ni registros**.

Situación	Acción
Sesión o token robado	Revocar las sesiones de la cuenta. Desde O17, la revocación compara en **milisegundos**, así que también muere el token emitido en el mismo segundo
Cuenta usada para atacar	Deshabilitarla
Abuso de un rol de personal	Bajarlo a USER (lo hace otro ADMIN) y revocar sus sesiones
`JWT_SECRET` filtrado	`incident:revoke-all-sessions` **y** rotar `JWT_SECRET`
Compromiso de la EC2 o del bucket	Aislar (*security group*), snapshot EBS **antes** de detener, revocar las políticas del bucket

5.4 Erradicación y recuperación

Erradicación:

- causa raíz con la reconstrucción y el código;
- corrección con una prueba e2e que reproduzca el ataque;
- rotar los secretos expuestos;
- eliminar los accesos creados por el atacante.

Recuperación:

- desplegar la corrección;
- `/enable` sobre las cuentas afectadas, con cambio de contraseña si corresponde;
- si se restaura un respaldo, reaplicar las supresiones registradas después de su fecha.

Antes de reabrir el servicio:

- [ ] Las suites pasan, incluida la prueba nueva.
- [ ] `audit/verify` → `ok: true`.
- [ ] No quedan alertas relacionadas en `OPEN` o `INVESTIGATING`.
- [ ] Los secretos están rotados y las sesiones anteriores invalidadas.
- [ ] Hay monitoreo reforzado durante 7 días.

5.5 Notificación

Plazos:

- **Evaluación interna:** ≤ 24 h desde la confirmación.
- **Comunicación a la Agencia:** ≤ 72 h desde la confirmación, aunque esté incompleta, y luego se complementa. La ley dice "por los medios más expeditos posibles y sin dilaciones indebidas" y no fija horas; las 72 h son una referencia de buena práctica (RGPD art. 33), no una obligación chilena.

Destinatario	Cuándo	Fundamento
Agencia de Protección de Datos Personales	Toda vulneración con "riesgo razonable para los derechos y libertades de los titulares"	Art. 14 sexies, inciso 1°

Destinatario	Cuándo	Fundamento
Titulares afectados (obligatorio)	Si afecta datos **sensibles** (art. 2 g), de **menores de 14 años**, o **relativos a obligaciones de carácter económico, financiero, bancario o comercial**. En este sistema son las **transacciones**: compras, ventas, montos y medio de pago	Art. 14 sexies, inciso 3°
Titulares afectados (decisión del plan)	Si afecta su **ubicación** (geolocalización). La ley no la cuenta como sensible (art. 2 g), pero puede revelar dónde vive un vendedor	Buena práctica
Titulares afectados (decisión del plan)	Si afecta sus **credenciales**, para que cambien la contraseña donde la reutilicen	Buena práctica
Proveedores (AWS, MercadoPago)	Si el incidente toca su servicio	Contratos
PDI o Fiscalía	Si hay un delito informático	Ley 21.459

Cómo se notifica a los titulares: a cada uno, a su correo, en lenguaje claro. Las cuentas se identifican con `pseudonyms/resolve`, con motivo y auditado. Si no se puede a cada uno, se publica un aviso en un medio masivo de alcance nacional (art. 14 sexies).

Registro de comunicaciones (art. 14 sexies, inciso 2°). En la ficha del incidente queda cada comunicación con:

- naturaleza de la vulneración;
- efectos;
- categorías de datos;
- número aproximado de titulares;
- medidas adoptadas;
- fecha, destinatario y quiénes la aprobaron.

Plantilla A — a la Agencia

> **Reporte de vulneración de medidas de seguridad — Ley 19.628, art. 14 sexies**
>
> **Responsable:** MTG Companion (Grupo MTG Companion). **Contacto:** [correo de seguridad] · **N.º interno:** INC-[n]
>
> 1. **Naturaleza de la vulneración:** [qué ocurrió: p. ej., toma de cuenta con credenciales obtenidas fuera del sistema, seguida de exportación de datos]. Detectada el [fecha y hora] por la regla [`regla`]; ocurrió entre [primer evento] y [último evento], según el registro de auditoría verificado (cadena íntegra: sí/no).
> 2. **Efectos:** [acceso no autorizado, filtración, alteración o destrucción], [confirmado o en investigación].
> 3. **Categorías de datos afectadas:** [de `dataCategories`: identificación, transacciones, geolocalización…].
> 4. **Número aproximado de titulares afectados:** [n] (sujeto + `affectedSubjects`).
> 5. **Medidas adoptadas para gestionarla:** [contención: sesiones revocadas a las hh:mm, cuenta deshabilitada, secretos rotados…].
> 6. **Medidas para precaver incidentes futuros:** [corrección, regla nueva o ajustada, cambios al plan].
> 7. **Comunicación a los titulares:** [sí, el (fecha), por correo individual / no corresponde, porque…].

> Aprobado por: [líder] y [segundo integrante] · Fecha: [fecha]

Plantilla B — a cada titular afectado

> **Asunto:** Aviso importante sobre la seguridad de tu cuenta de MTG Companion
>
> Hola [alias],
>
> 1. **Qué pasó:** el [fecha] detectamos que [explicación en una o dos frases, sin tecnicismos].
> 2. **Qué datos tuyos se vieron afectados:** [lista concreta: tu historial de compras y ventas (cartas, montos, medio de pago) / tu ubicación aproximada (~1 km) / tu correo y alias].
> 3. **Qué podría significar para ti:** [consecuencias posibles: alguien podría saber qué compraste y a qué precio / la zona aproximada donde estás / podrías recibir correos falsos haciéndose pasar por nosotros].
> 4. **Qué hicimos:** [cerramos todas las sesiones de tu cuenta, bloqueamos el acceso no autorizado, corregimos el problema el (fecha)].
> 5. **Qué te recomendamos:** cambiar tu contraseña (y donde la uses también), activar la verificación en dos pasos y desconfiar de mensajes que pidan tus datos. [Si fue la ubicación: puedes retirar el consentimiento de ubicación en Privacidad y mis datos.]
> 6. **Contacto:** responde a este correo o escribe a [correo de seguridad] indicando el caso INC-[n]. También puedes reclamar ante la Agencia de Protección de Datos Personales.

5.6 Lecciones aprendidas y cierre

Revisión sin culpables, en los 14 días siguientes. Deja en la ficha:

- la línea de tiempo (el `.md` de `incident:timeline` se adjunta tal cual);
- la causa técnica y la organizativa;
- las medidas correctivas y preventivas como filas de `ROADMAP.md`;
- los umbrales a ajustar en `detection-rules.ts`.

Condiciones para cerrar (alerta → `CLOSED`):

- causa erradicada;
- §5.4 cumplida;
- notificaciones enviadas y registradas, o la decisión fundada de no notificar;
- revisión hecha.

---

6. Guía de actuación por tipo de incidente (propios del sistema)

Alerta	Primeras preguntas (con la reconstrucción)	Contención	¿Notificar?
`bazaar.location.triangulation`	¿Desde cuántas celdas buscó? ¿Qué vendedores aparecían en esas búsquedas (`sellers=N`)? ¿Fue un bot o una persona?	Automática: sesiones revocadas. Si se repite, deshabilitar la cuenta	Si se confirma que obtuvo distancias de vendedores concretos: Agencia (riesgo razonable) y esos vendedores (decisión del plan)

Alerta	Primeras preguntas (con la reconstrucción)	Contención	¿Notificar?
`account.takeover.sequence`	¿El cambio de correo lo hizo el titular? (Se le escribe a la dirección **anterior**, que recibió el aviso.) ¿Qué se exportó o borró?	Automática: sesiones revocadas. Deshabilitar, devolver el correo al titular y forzar el cambio de contraseña	Si no fue el titular: Agencia y titular (la exportación incluye **transacciones** → obligatorio)
`transactions.enumeration`	¿Alguna lectura ajena fue ALLOWED, o todas DENIED? ¿Sobre qué ids?	Si todas fueron DENIED: vigilar. Si hubo una ALLOWED ajena, es una falla de control de acceso: ALTA, corregir de inmediato	Solo si hubo acceso ALLOWED a transacciones ajenas: Agencia y titulares afectados (obligatorio)
`admin.reidentification.burst`	¿Había un caso abierto que lo justifique (motivos en `reason`)? ¿A quiénes re-identificó?	Otro ADMIN baja el rol a USER y revoca sesiones mientras se investiga	Si fue abuso: Agencia; titulares según los datos que el ADMIN haya visto después